



软件全生命周期供应链安全管理



孝道科技 徐锋

不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn

目录

1 软件供应链安全概述

2 甲方视角的软件供应链安全

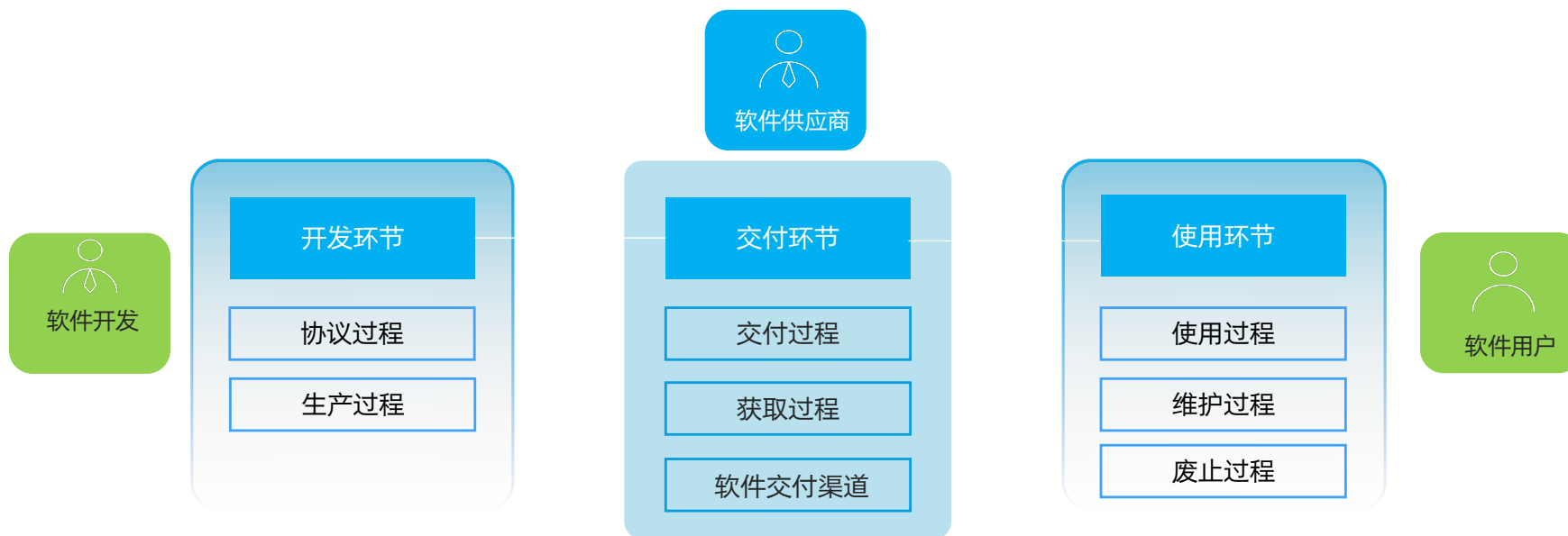
3 自研（乙方）视角的软件供应链安全

国内软件供应链安全政策标准日益完善

- 2022年：GB/T 39204 《信息安全技术 关键信息基础设施安全保护要求》,7.9提出供应链保护要求
- 2023年：GB/T 42927 金融行业开源软件测评规范
- 2024年：GB/T 43848 软件产品开源代码安全评价方法
- **2024年：GB/T 43698 软件供应链安全要求**
- 2026年：GB/T 47020 软件物料清单数据格式
- 2026年：GB/T XXXXX 关键信息基础设施安全检测评估方法（征求意见稿）,6.1.4 供应链安全 作为基础保护能力检测项

● 软件供应链安全定义

软件供应链安全：指软件供应链上全生命周期各个阶段的安全，包括供应活动、本身的编码过程、工具、设备或供应链上游的代码、模块和服务以及软件交付渠道及使用过程安全的总和。



● 软件供应链安全目标

建立并完善软件供应链安全风险管理能力体系，持续增强与软件供应链安全紧密相关的风险管理、组织管理和供应活动管理能力，防范各类**软件供应链安全风险，保障业务持续稳定和安全运行。**

提升

软件供应链韧性

软件供应链安全性

软件供应链合规性

防范

供应关系安全风险：软件产品和服务的供应中断或降级等
技术安全风险以及其衍生的数据安全风险：供应活动引入的漏洞、后门、数据泄露等安全风险。

外部组件使用不合规及知识产权安全风险：违反开源许可协议、专利侵权、商标侵权等。

阶段一:项目立项

核心活动

定义业务安全需求、制定项目计划。

固有脆弱点

安全目标缺失

项目目标中未明确安全要求,导致安全投入不足。

供应链复杂性低估

未充分考虑引入第三方组件和供应商带来的潜在风险。

阶段二:软件采购

核心活动

招标、供应商选型、合同签订。

固有脆弱点

安全要求不明确

采购文件中未对软件的安全能力、SBOM提供等做出明确要求。

供应商评估缺失

未对供应商的安全开发能力、历史安全事件等进行充分评估。

单一来源风险

过度依赖单一供应商,缺乏替代方案。

合同中缺少供应链安全责任约束

安全开发义务
交付安全义务
安全维护责任
紧急避险条款

阶段三:软件开发

核心活动: 设计、编码、测试、集成,是漏洞产生的主要环节。

固有脆弱点

安全开发能力不足

缺乏安全需求分析、安全设计、安全编码规范、代码审查和安全测试流程。

开源组件管理混乱

使用带有已知漏洞的开源组件,或违反许可证协议。

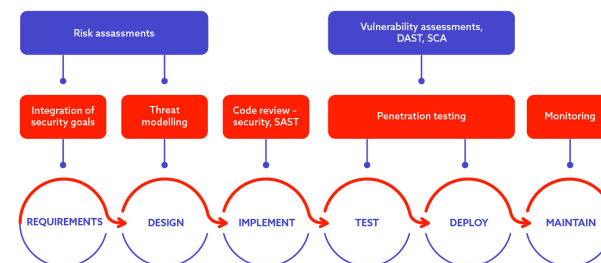
开发环境不安全

开发工具被污染,开发人员凭证泄露。

CI/CD流水线漏洞

构建过程缺乏完整性保护,配置不当。

Secure software development lifecycle (SSDLC)



阶段四:软件交付

核心活动: 打包、分发、安装、验收。

固有脆弱点

交付物被篡改

软件在传输过程中被中间人攻击或仓库被入侵。

文档与资料不全

未提供完整的源代码、技术文档、SBOM、安全配置指南等。

配置错误

软件或基础设施的安全配置不当。

隐藏功能或后门

交付的软件包含未声明的功能或恶意代码。



SBOM是交付环节不可或缺的技术文档,可清晰展示软件构成,支撑完整性与安全性核验。

阶段五:线上运维

核心活动: 运行监控、漏洞修复、版本更新、故障处理。

固有脆弱点

软件资产台账不清

缺少SBOM或更新不及时。

补丁管理滞后

未能及时应用安全补丁,导致漏洞被利用。

运维工具风险

使用的运维工具自身存在安全问题。

第三方运维风险

供应商远程运维权限过大或操作不规范。



● 生命周期脆弱点分析

阶段六:软件废止

核心活动: 停用、卸载、数据迁移、销毁。

固有脆弱点

数据泄露

废止软件时,存储在其中的敏感数据未被安全销毁。

权限残留

与废止软件相关的账户、权限未被及时清理。

知识流失

关键软件的技术文档和知识未被妥善归档。



软件全生命周期供应链安全管理框架



软件供应链安全治理体系

供应链安全性

供应链韧性

供应链合规性

软件立项

软件采购

软件开发

软件交付

软件运维

软件废止

软件供应链全生命周期管控措施要素

系统安全防护需求
供应链风险防范要求
可研方案评审

明确供应链责任
供应商安全评估
供应链安全协议

安全需求分析与评审
安全设计方案与评审
组件安全选型
安全编码

安全测试方案与评审
代码安全管理
开发测试环境管理
软件发布安全评审

软件安全检测
软件入库备案
知识转移
安全部署与加固
入网安全质量红线

持续安全监测
持续安全扫描
风险预警
应急响应
变更管理

系统下线评估
软件版本退出评估

软件供应链流程制度建设

项目立项评审流程
系统安全定级流程

采购管理流程

需求评审流程
设计评审流程
组件引入流程

漏洞管理流程
软件测试流程
软件发布流程

系统部署流程
项目验收流程
系统入网流程

安全监测扫描流程
风险预警与处置流程
变更管理流程

系统下线流程

项目管理制度

供应商管理制度

安全开发管理办法

开源软件管理办法

业务系统
上线安全管理办法

运维安全管理制度

软件供应链安全管理

软件供应链安全工具链建设

软件供应链安全检测类

软件安全防护类

安全审计类

安全开发管理类系统

软件供应链安全管理与威胁情报

不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn

甲方视角-软件供应链安全建设框架

① 软件供应链安全能力安全评估体系

生产过程安全

安全开发
过程

安全开发
工具

安全开发
环境

安全管理
制度

软件安全与运营

漏洞
缺陷

运行安
全防护

开源
风险

安全应
急保障

供应商基础信息

资质

信誉...

历史履责纪录

漏洞
响应

安全
事件

② 软件供应链安全检测中心

产品对象管理

漏洞管理

工具管理

报告管理

安全检测原子能力

SAST

SCA

IAST

DAST

容器安全扫描

laC.....

③ 软件供应链安全态势管理平台

供应商信息“一清单”

威胁信息“一张图”

软件资产“一本账”

供应链风险“一览表”

软件资产管理

供应商管理

软件供应链安全态势感知与处置

软件属性信息

供应商风险

供应链威胁情报

软件成分信息

供应商产品信息

供应商威胁预警

软件漏洞信息

供应商人员管理

供应链威胁处置

软件许可信息

供应商基础信息

供应链情报共享

供应商基础
信息库

软件
资产库

产品
漏洞库

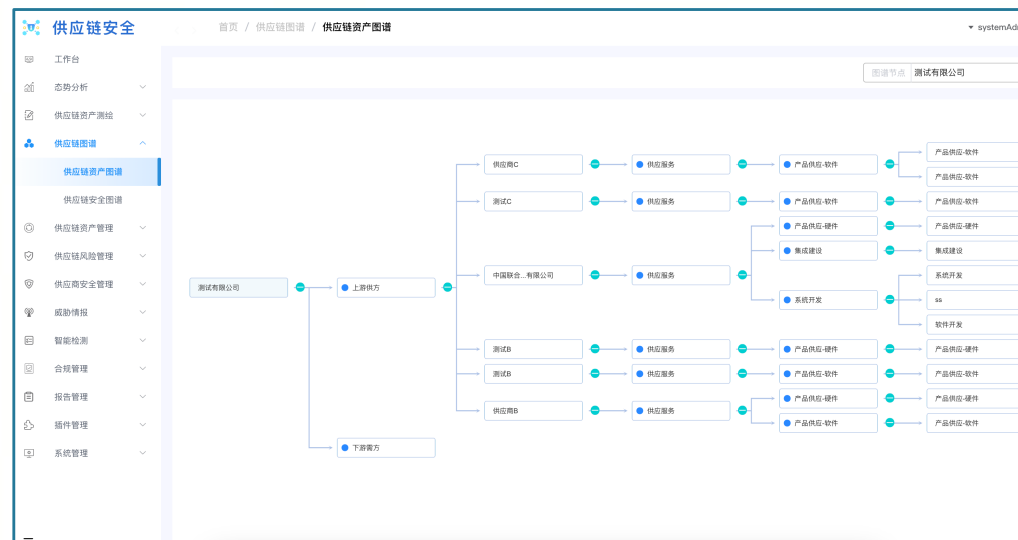
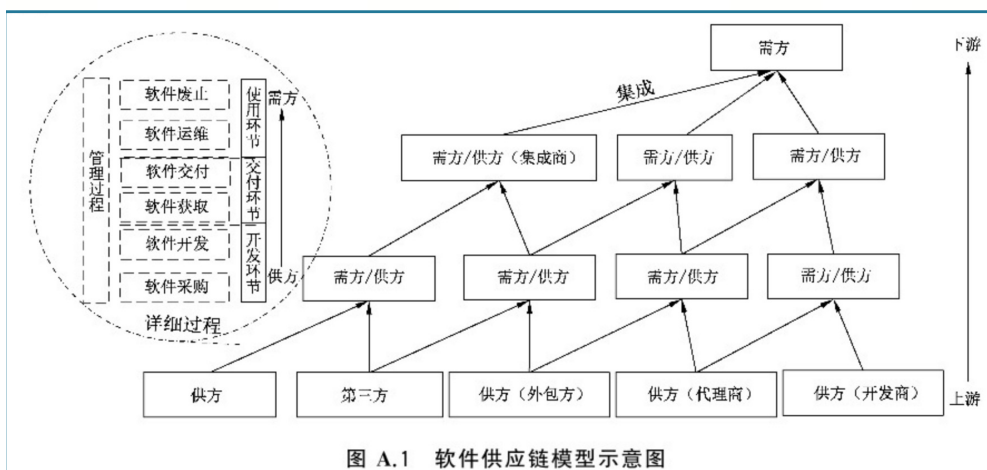
开源软件
漏洞库

供应链威胁
情报库

不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn

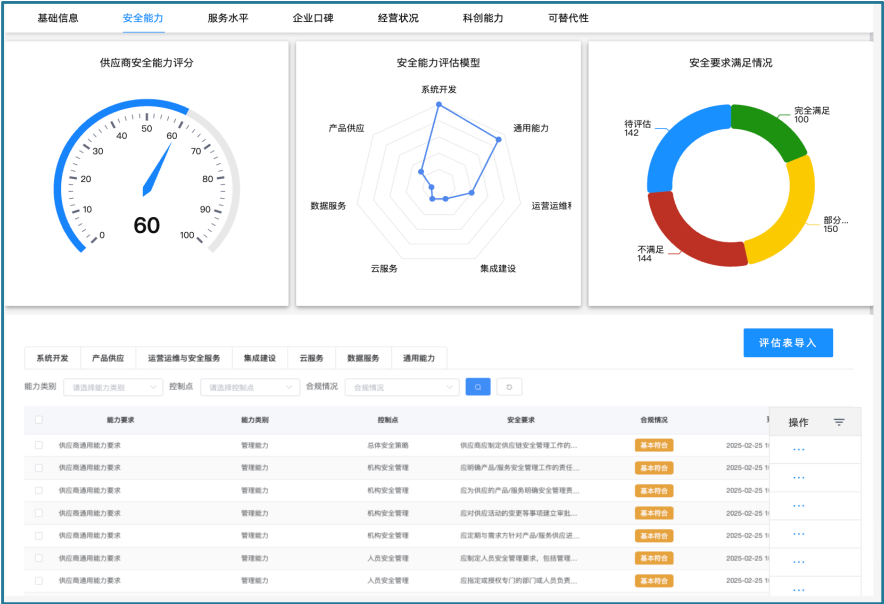
软件供应链供应关系管理

软件供应链是一种由供应关系、供应活动构成的网链结构。软件供应链至少包含一层供应关系，种实体可以有多种角色。平台基于软件供应链模型，将实体角色（供方、需方）、供应关系、供应活动进行关联，动态构建为供应链资产图谱。



供应商风险评估与管理

对供应商进行管理分类分级建立合格的供应目录,对供应目录及相关信息集中管理,对供应商进行风险评估分析。



供应商安全评估模型

多维供应商安全评价体系
不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn

软件供应链安全图谱

软件供应链安全图谱包含软件产品信息、软件物料清单和安全信息3方面内容。其中,安全信息是指软件物料清单中的组件、代码中存在的技术安全和合规安全信息。软件供应链安全图谱一般以文本形式存储,支持通过知识图谱方式展示。



1.应用资产识别

基于软件成分分析技术,分析业务应用中的外部组件,生成软件物料清单(SBOM)。

2.安全风险关联

基于源代码安全审计、开源组件风险分析、交互式应用安全检测技术,获取应用软件中的安全信息。

3.资产图谱构建

集合软件产品信息、软件物料清单和安全信息,动态构建软件供应链安全图谱,并通过知识图谱方式展示。

软件供应链安全技术风险检测

供应链AI检测智能体集成源代码安全审计、开源组件风险分析、交互式应用安全等检测引擎综合分析软件安全技术风险。

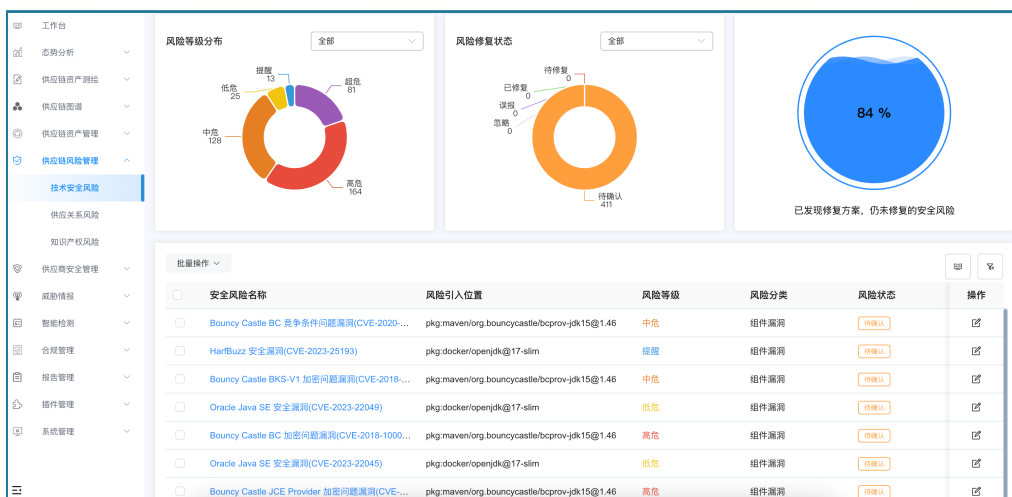


不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn



软件供应链安全风险威胁情报与处置管理

针对供应关系风险（如：供应商经营异常、开源项目停服断供等）、技术安全风险(软件漏洞、投毒等)、知识产权风险（开源许可变更）等供应链威胁持续监测与预警。

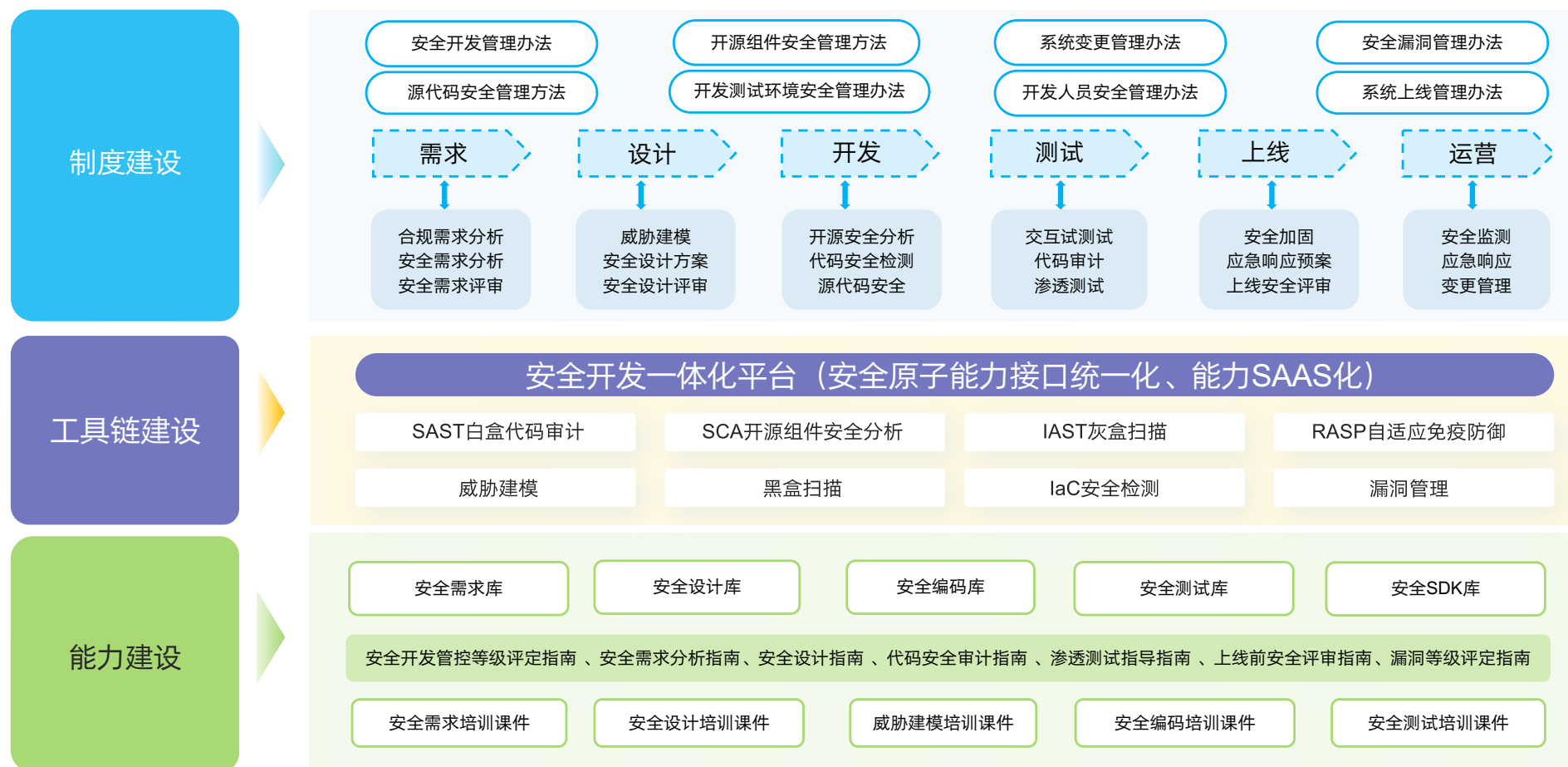


供应链风险统一运营管理



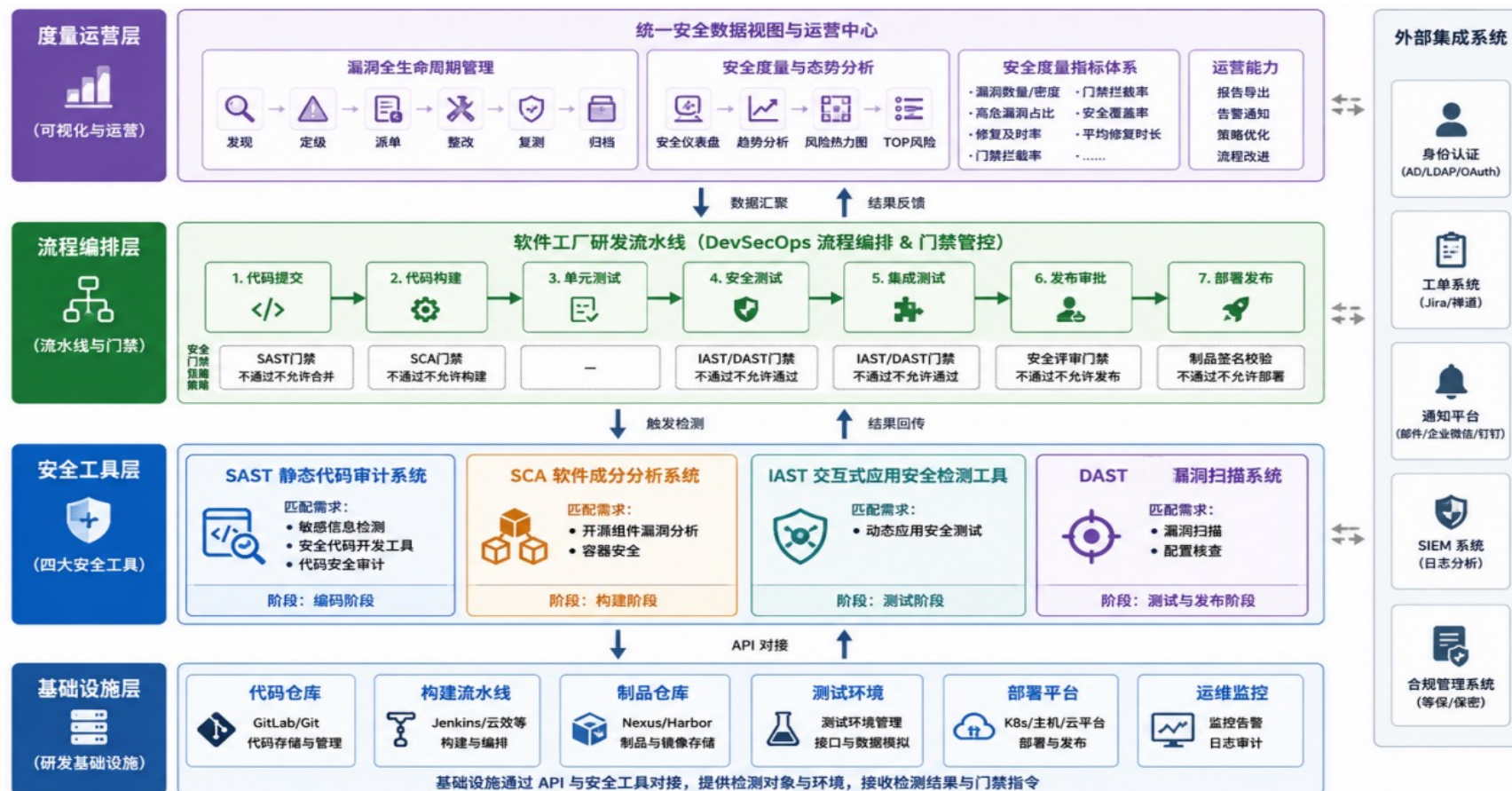
供应链威胁情报监控

自研视角-软件安全开发体系建设



不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn

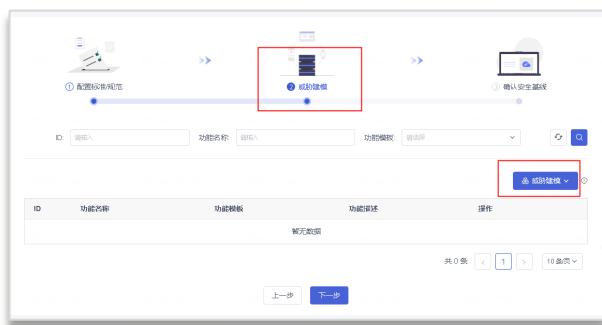
DevSecOps集成架构



图例: 度量运营层 (可视化与运营) 流程编排层 (流水线与门禁) 安全工具层 (四大安全工具) 基础设施层 (研发基础设施) ———> 数据流向 - - -> 集成对接

个定需安更多的女王软件, 且定需更安全的软件
www.tcsec.com.cn

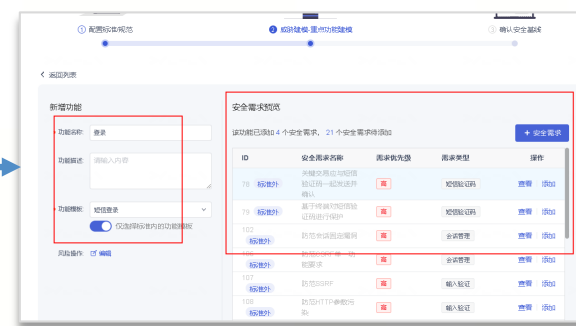
AI Agnet威胁建模、自动输出、降本提效



- 威胁建模系统，根据需求文档、业务场景，自动输出**安全需求清单**、**安全设计方案**、**安全需求测试用例**，解决威胁建模过程复杂、缺少安全专家、缺少安全测试人员和安全测试用例等问题。



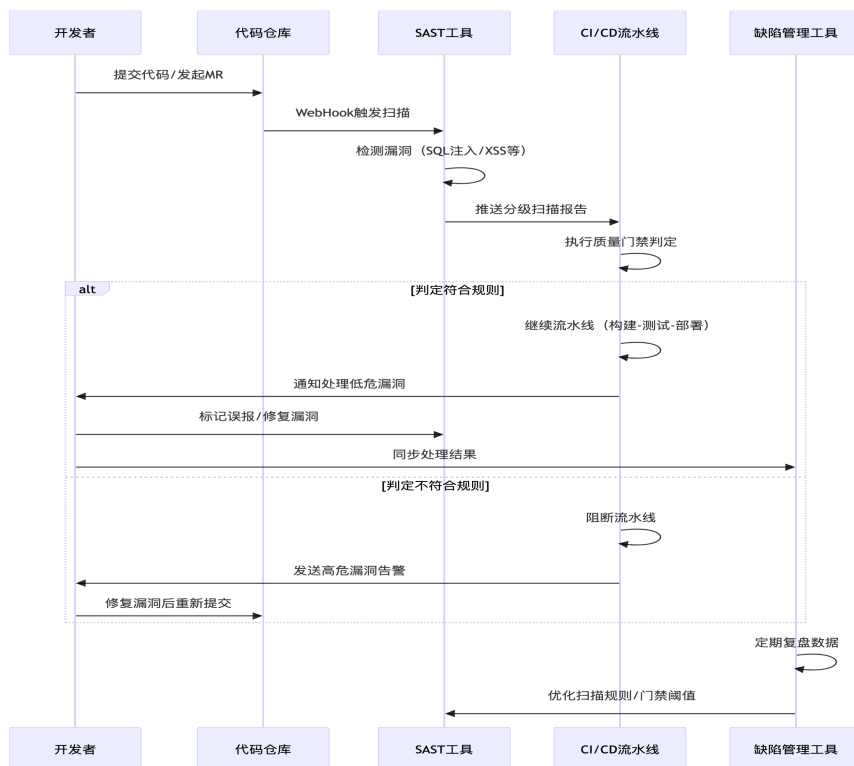
- 基于业务需求自动生成安全需求清单、安全设计、测试用例
- 多维度导出安全需求研发文档和测试文档
- 联动安全检测工具，实现自动闭环



不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn

SAST扫描前置、分级管控、持续提效

SAST（静态应用安全测试）是不运行代码的前提下，通过分析源代码、字节码文件，识别代码层面的安全漏洞、质量缺陷、合规性问题的工具。



- 核心逻辑：以代码提交为起点，通过 SAST 工具在 CI/CD 流水线中设置 “安全门禁”，实现漏洞的早发现、早处理。
- 分级处理：高危漏洞直接阻断流水线，低危漏洞允许发布但需后续闭环，兼顾安全性和研发效率。
- 持续优化：通过缺陷管理工具的复盘数据反哺 SAST 工具，形成 “扫描 - 处理 - 优化” 的闭环，提升安全检测能力。
- AI审计：通过模型能力对海量漏洞进行降噪

● 开源组件深度清点、开源风险动态管控

供应链威胁检测分析

- 开源组件漏洞风险识别
- 开源许可合规风险分析
- 开源组件投毒风险分析
- 基于AI的二进制识别检测
- 代码自研率分析
- 自动修复依赖项

CI/CD流程嵌入

- IDE编码、编译构建
- 应用打包、应用部署
- 源头控制、准入准出



● 开源可信中心仓、开源风险源头管控

面向对开源组件引入失控、开源漏洞、开源投毒风险等长期痛点，构建源头可信、全程可控、风险可管的开源可信中心仓。

• 安全风险前置阻断

从源头拦截投毒组件、高危漏洞，避免事后补救与生产入侵。

• 合规风险全域闭环

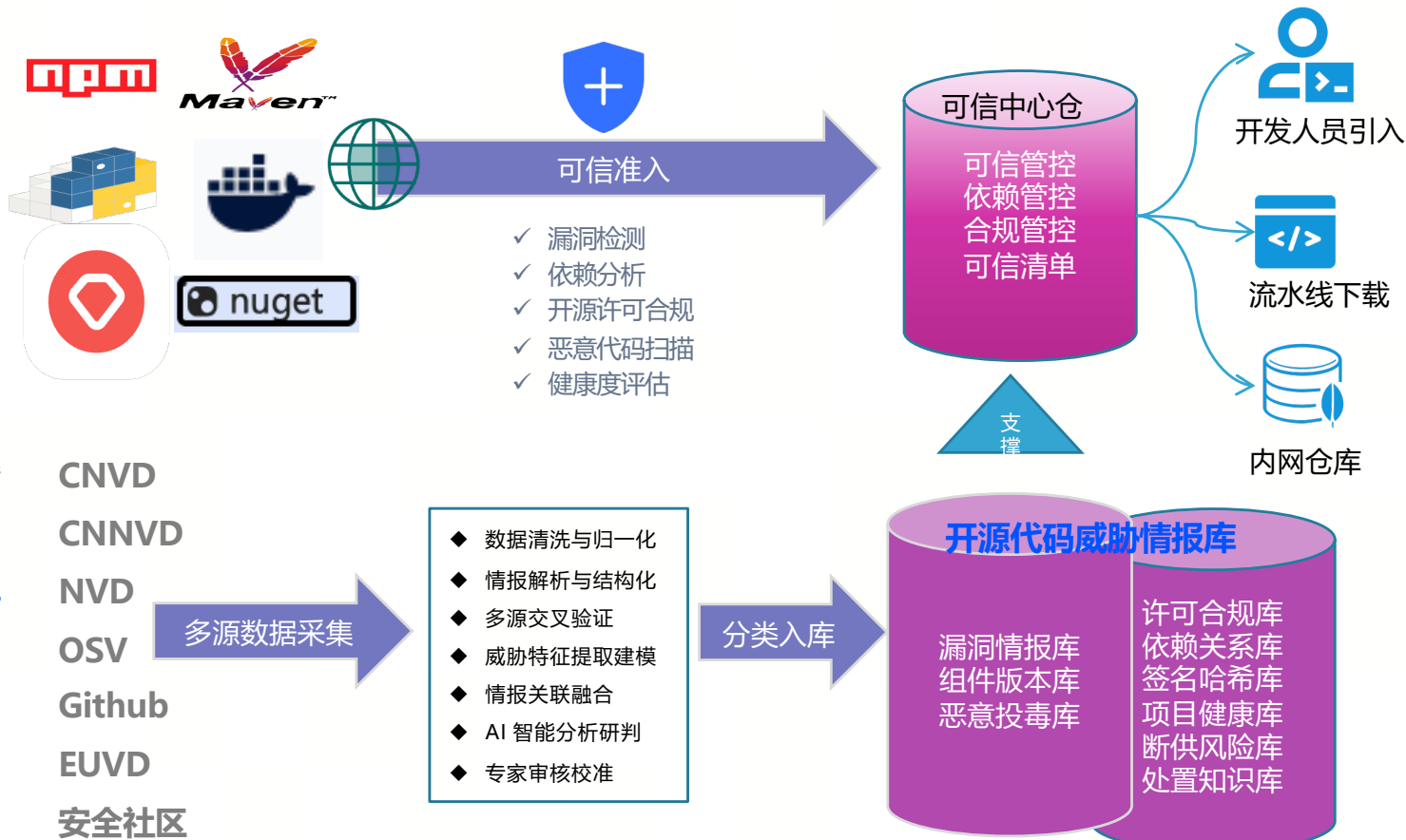
统一许可管理、版权溯源，杜绝开源合规风险。

• 组件资产集中治理

版本收敛、禁用废弃/高危组件，解决依赖混乱、版本泛滥、隐性引用问题。

• 开源风险响应效率显著提升

基于开源威胁情报库结合软件物料清单能及进溯源漏洞位置和影响范围。



不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn

IAST动态同步检测、全域动态风险识别

灰盒交互式安全测试系统（IAST）基于AI的智能污点分析，面向Web应用后台实现功能测试与安全测试同步，不产生脏数据和脏操作，动态检测代码层安全漏洞、开源组件风险、API接口安全、数据安全等。



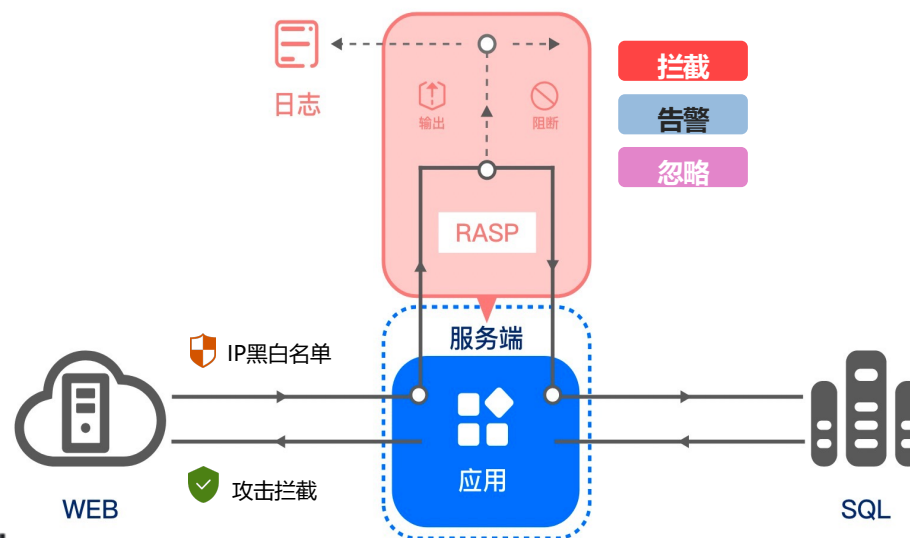
AI驱动的IAST



● 内嵌防护、精准阻断、自适应防护



RASP利用插桩技术实现应用系统（Web应用或服务）实现免疫防护，精准识别恶意攻击并实时告警或拦截。



- 防御0day漏洞
- 防护WebShell
- 防护内存马

- CVE漏洞靶向修复
- API梳理
- 开源组件风险识别

不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn



安全开发管理平台、安全开发数据统一呈现



安全需求概览 ①



漏洞情况统计 ①

全部 未闭环



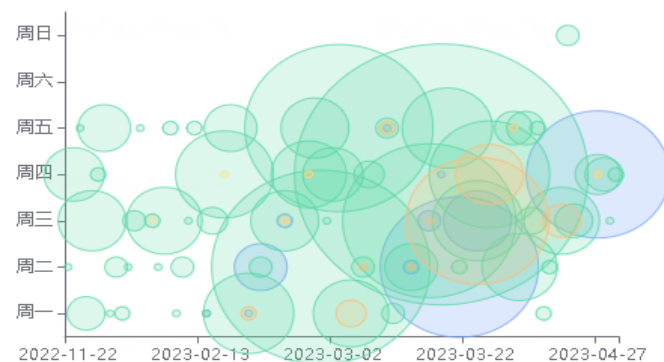
修复概览 ①

全部 忽略低危



安全检测频率 ①

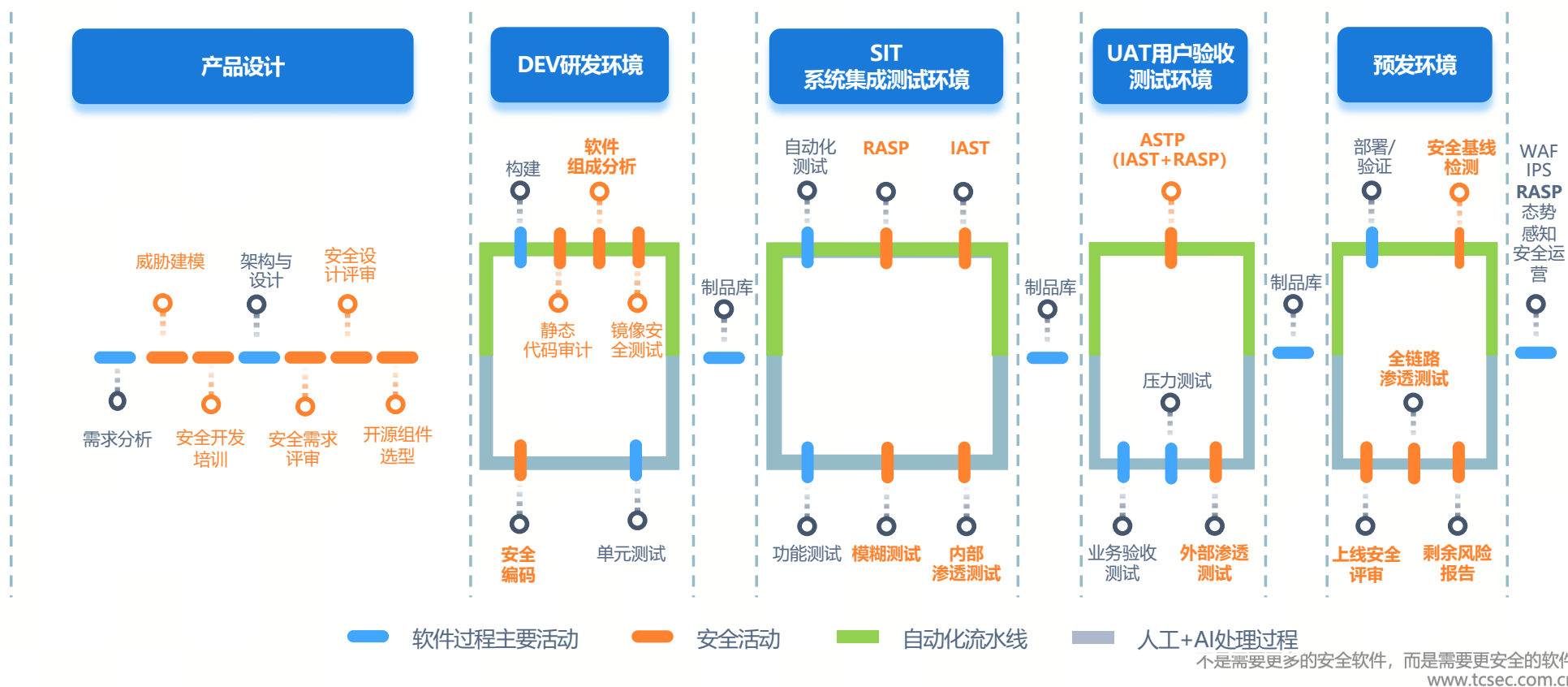
主机安全检测 静态安全检测 动态安全检测 APP安全检测



不是需要更多的女王软件，而是需要更安全的软件
www.tcsec.com.cn

● 左移防护、纵深检测、自适应免疫防护

整体开发过程落实“左移防护、纵深检测、自适应免疫防护”



AI 赋能阶段的DevSecOps



智能安全需求分析

- ✓ **AI需求建模：**利用AI解析需求文件，自动识别潜在安全约束。
- ✓ **威胁建模与预测：**结合情报预测新型威胁，转化为具体防护策略。

安全Agent Team自动化检测

- ✓ **多工具协同作战：**集成SAST/SCA/IAST/DAST等工具，构建自动化检测矩阵。
- ✓ **智能聚合：**AI优化自动关联聚合同类漏洞，消除噪音。

漏洞自动化处置

- ✓ **AI辅助修复：**基于代码大模型自动生成修复建议，实现“一键修复”。
- ✓ **验证与推送：**自动触发回归测试验证有效性，安全补丁自动推送。

智能化管理

- ✓ **应用态势感知：**分析海量数据，可视化展示风险分布并预警。
- ✓ **Agent Team：**协同管理多Agent完成，AI安全开发专岗。

不是需要更多的安全软件，而是需要更安全的软件
www.tcsec.com.cn



感谢聆听!

杭州孝道科技有限公司

Hangzhou Xiaodao Technology Co., Ltd.

官网: www.tcsec.com.cn

邮箱: service@tcsec.com.cn



不是需要更多的安全软件, 而是需要更安全的软件
www.tcsec.com.cn